

Разработка прототипа UEBA системы.

0. Введение

Разработка прототипа UEBA-системы сопровождалась серией инженерных решений, каждое из которых было принято на основе анализа результатов. В данном разделе последовательно рассматриваются ключевые решения, принятые в ходе разработки, с обоснованием их корректности.

1. Выбор архитектуры модели

Решение 1. Использование автоэнкодера вместо классических моделей классификации

Проблема. В задаче UEBA отсутствует размеченный датасет атак — по определению, аномалии редки и разнообразны, и их невозможно заранее каталогизировать.

Решение. Применён автоэнкодер — нейросеть, обучаемая восстанавливать нормальное поведение. Аномалией считается любое состояние, ошибка реконструкции (MSE) которого превышает порог.

Обоснование. Этот подход имеет три ключевых преимущества:

- Не требует размеченных данных об атаках
- Автоматически адаптируется к поведению конкретного пользователя
- Способен детектировать ранее неизвестные аномалии

Результат тестирования. На валидационной выборке (308 примеров) модель достигла Median MSE = 0.24, что свидетельствует о качественном обучении нормальному поведению.

Решение 2. Размер bottleneck-слоя (4 нейрона) и структура скрытых слоев (18-32-16-8-4-8-16-32-18)

Проблема. При слишком узком bottleneck модель теряет информацию, при слишком широком — перестаёт быть селективной. При меньшем количестве слоев модель не способна понять закономерности и ValLoss получается значительно выше.

Решение. Выбран bottleneck размером 4 нейронов при 18 входных признаках. И структура с 7 скрытыми слоями.

Обоснование. Это значение обеспечивает баланс между способностью к обобщению и сохранением информативности. Экспериментально подобрано в ходе серии запусков.

Результат тестирования. Early stopping сработал на эпохе 343 из 1000, итоговый Val Loss = 1.79 — модель не переобучилась.



Решение 3. Использование RobustScaler вместо StandardScaler

Проблема. Системная телеметрия содержит экстремальные выбросы (например, разовое обновление Windows может дать всплеск трафика в 1000× от нормы). StandardScaler, использующий среднее и стандартное отклонение, крайне чувствителен к выбросам.

Решение. Применён **RobustScaler**, основанный на медиане и межквартильном размахе.

Обоснование. Медиана и IQR являются робастными статистиками — выбросы практически не влияют на их значения. Это обеспечивает стабильную нормализацию даже при наличии экстремальных значений.

Результат тестирования. После применения RobustScaler распределение признаков стало согласованным: все признаки имеют масштаб $\sim[-3, +3]$, что позволило модели корректно обучаться.

Решение 4. Удаление экстремальных выбросов при обучении

Проблема. Анализ обучающих данных выявил строки с $MSE > 46000$, связанные с обновлениями Windows (7.6 МБ/с входящего трафика + 1300 событий успешного входа). Такие выбросы завышают порог аномальности и снижают чувствительность модели к реальным атакам.

Решение. Строки со значениями выше 99.5-го перцентиля по любому признаку удаляются из обучающей выборки.

Обоснование. Автоэнкодер физически не способен «выучить» событие, которое встречается 1–2 раза за 1400 примеров. Удаление таких строк позволяет модели сконцентрироваться на устойчивых паттернах нормального поведения.

Результат тестирования. После очистки Max MSE снизился с 93198 до 45, порог аномальности стал адекватным: ~12 вместо 218.

Решение 5. Двухуровневая агрегация (1 мин → 10 мин)

Проблема. Случайные всплески активности пользователя (открытие тяжёлого приложения, VPN-подключение) длятся недолго и создают ложные срабатывания. Вредоносное ПО, напротив, работает устойчиво в течение длительного времени.

Решение. Данные агрегируются каждую минуту, затем последние 10 минут усредняются для формирования окна мониторинга.

Обоснование. Это элегантное решение обеспечивает математически корректную масштабизацию всех типов признаков:

- Для средних значений: `mean(mean_1, ..., mean_10) = mean(все данные за 10 минут)`
- Для счётчиков: `(sum_1 + ... + sum_10) / 10 = average per minute`
- Для уникальных значений: корректное среднее количество уникальных IP/портов в минуту

Результат тестирования. Кратковременные всплески «размазываются» по окну и не вызывают алерта, тогда как устойчивые аномалии (майнер, брутфорс) сохраняются во всех 10 окнах и надёжно детектируются.

Решение 6. Обучение на 1-минутных агрегированных данных вместо 10-минутных

Проблема. На этапе проектирования встал вопрос о размере окна агрегации для обучающих данных. Изначально планировалось использовать 10-минутные окна, что соответствует окну мониторинга. Однако это приводило к критическому последствию: за 24 часа обычного использования ПК накапливается лишь 144 примера, что недостаточно для стабильного обучения нейросети. Для получения выборки в 1000+ примеров потребовалось бы собирать данные около 10 дней, что неприемлемо для учебного проекта.

Решение. Обучающие данные агрегируются с окном **1 минута**, тогда как мониторинг в реальном времени выполняется с окном **10 минут**. Это позволяет за 24 часа собрать ~1400 примеров для обучения, что достаточно для стабильной работы автоэнкодера.

Обоснование корректности: Данное решение основано на линейности матожидания: усреднение данных за 10 одномоментных окон имеет для каждого признака такое же мат ожидание как для признаков одномоментном окне. Следовательно норма - остается нормой.

Повышенная робастность такой модели: 1-минутные данные имеют большую дисперсию, чем 10-минутные. Модель, обученная на более «шумных» данных, становится устойчивее к кратковременным всплескам активности.

Модель, обученная на 1-минутных данных, напрямую применяется к 10-минутным агрегатам без дополнительной адаптации.

Результат: Выбор 1-минутного окна агрегации для обучения является обоснованным решением, которое:

- Сокращает время подготовки данных с 10 дней до 24 часов
- Увеличивает объём обучающей выборки в 10 раз
- Повышает робастность модели за счёт большей дисперсии данных
- Остаётся математически корректным при применении к 10-минутным окнам мониторинга
- Не требует переобучения при изменении параметров мониторинга

Это решение однозначно хорошее.

Решение 7. Порог на 95 перцентиль + Подтверждение аномалии (2 окна подряд) + cooldown

Проблема. 1)при большом пороге - аномалии не будут детектироваться. 2)при маленьком пороге - будет огромное количество ложных срабатываний, даже при использовании 10 минутных окон агрегации.

Решение. Порог оставлен на 0.95 перцентиль - это гарантирует чувствительность к угрозам. Алерт генерируется только если 2 окна подряд (20 минут) имеют MSE выше порога. Дополнительно введён cooldown — повторные алерты по той же аномалии не генерируются в течение 10 минут.

Обоснование. Вероятность двух ложных срабатываний подряд при $FPR = 5\%$ равна $0.05^2 = 0.0025$, что теоретически даёт ~0.35 ложных алерта в день (и это без учета падения дисперсии от 10 минутной агрегации). При этом реальные атаки (майнер работает часами, брутфорс — минутами) гарантированно детектируются.

Результат тестирования. в течение 10 часового тестирования не обнаружено ложных срабатываний. Предполагая распределение ложных срабатываний по пуассону, приходим к экспериментальной оценке: с вероятностью 95% кол-во ложных срабатываний не превышает 0.05 срабатываний в час.

Решение 8. Валидация системы на шести симуляциях атак

Проблема. Необходимо проверить способность модели детектировать аномалии и атаки.

Решение. Разработан набор из шести симуляций реальных атак, каждая из которых генерирует характерный поведенческий паттерн.

Обоснование выбора шести типов угроз. Набор построен по принципу покрытия ключевых признаков и наиболее распространенных угроз.

Таблица 6 — симуляции симуляций

Симуляция	Задействованные признаки
Brute-Force	<code>failed_logins</code>
Cryptomining	<code>cpu_avg</code> , <code>cpu_max</code>
Ransomware	<code>disk_write_bytes_total</code> , <code>cpu_avg</code>
Port Scanning	<code>unique_dst_ports_count</code>
Exfiltration	<code>bytes_sent_avg</code> , <code>unique_dst_ips_count</code>
C2 Beaconing	<code>active_connections_max</code>

Шесть симуляций покрывают большую часть признаков, и являются весьма распространенными. При этом задействуются все типы признаков: вычислительные, дисковые, сетевые и логи безопасности.

Безопасность симуляций. Все сценарии безвредны: брутфорс использует несуществующего пользователя, криптоджекинг — только математические вычисления, ransomware — файлы во временной папке с автоудалением, сетевые симуляции работают только на 127.0.0.1 .

Решение 9. Behavior-based классификация вместо attack-based

Проблема. Первоначальный подход пытался угадать конкретный тип атаки (майнер / рансомвер / эксфильтрация) по косвенным признакам. Тестирование показало ошибки классификации:

- Майнинг детектировался как Ransomware
- Эксфильтрация — как Port Scan
- C2-маячки — как Network Scanning

Решение. Переход к классификации **по типу аномального поведения**: «Аномальная нагрузка на CPU», «Подозрительная аутентификация», «Аномальная исходящая сетевая активность» и т.д.

Обоснование. Такой подход:

- **Честен:** система описывает, что именно аномально, а не гадает о типе атаки
- **Точен:** каждый признак однозначно связан с одним типом аномалии

Результат тестирования. После перехода на behavior-based классификацию все 6 сценариев атак классифицированы корректно:

Симуляция	Тип аномалии	Уверенность
Брутфорс	Подозрительная аутентификация	90%+
Майнинг	Аномальная нагрузка на CPU	85%+
Шифровальщик	Аномальная дисковая активность	80%+
Сканирование портов	Сканирование портов	75%+
Экспфильтрация	Аномальная исходящая сетевая активность	80%+
C2-маячки	Множество сетевых соединений	70%+

Решение 10. Эвристическая четырехкомпонентная система оценки уверенности

Проблема. Необходимо оценивать уверенность модели в детекции аномалии, чем выше MSE - тем больше уверенность, чем больше отклонение признаков от нормы - тем больше уверенность и т.д.

Решение. Уверенность вычисляется по формуле:

```
1 confidence = base + f(MSE/threshold) + g(deviation_features) + h(conditions_matched)
```

где:

- **base** — априорная уверенность типа аномалии (0.30–0.60) (сетевая активность/запись на диск - могут быть легитимными. Много неудачных попыток входа - это почти гарантированная атака)
- **f** — бонус за превышение MSE над порогом (логарифмическая шкала, [0; 0.15])
- **g** — бонус за силу отклонения признаков от P95 ([0; 0.25])
- **h** — бонус за полноту срабатывания правила ([0; 0.10])

Обоснование. Аддитивная модель обеспечивает интерпретируемость: понятно, из каких компонентов сложилась итоговая уверенность. Логарифмическая шкала для MSE нужна для ограничения значений при экстремальных атаках.

Результат тестирования. При симуляции брутфорса (874 неудачных входа при P95 = 1) уверенность составила 90%+, при слабой аномалии (MSE = 12 при пороге 12) —

35%, что отражает силу сигнала.